IT Security, Passwords and Access Management Guide

This document covers IT security policies, password management, MFA setup, SSO, data classification, and phishing prevention.

1. Password Policy

1.1 Password Requirements

- Minimum length: 12 characters.
- Must contain: uppercase, lowercase, number, and special character (!@#$%^&*).
- Cannot reuse your last 12 passwords.
- Expiry: Every 90 days. Email reminders sent at 14, 7, and 1 day before expiry.
- Account lockout: 5 failed attempts = 15-minute lockout. 10 failed = IT unlock required.

INFO: IT staff will NEVER ask for your password. Do not share passwords with anyone.

1.2 Resetting Your Password

- Self-service: https://password.company.com (requires pre-configured MFA).
- IT Helpdesk: Call 1800-IT-HELP or submit a ticket at https://helpdesk.company.com.
- In-person: Bring your employee badge to IT Service Desk, Building A, Room 101.
- After reset, update password on all enrolled devices within 24 hours.

1.3 LastPass Password Manager

- Access at: https://lastpass.company.com
- Install the browser extension for Chrome, Firefox, or Edge.
- Use LastPass to generate and store strong passwords for all non-SSO applications.

2. Multi-Factor Authentication (MFA)

2.1 Enrolling in MFA

- Go to https://mfa.company.com and sign in with your AD credentials.
- Supported methods (best to least secure): YubiKey hardware key, Microsoft Authenticator, Google Authenticator, SMS OTP.
- Enroll at least 2 methods as backup.

2.2 Lost MFA Device

- Call IT Security immediately: 1800-IT-SEC (24 hours a day, 7 days a week).
- You will be verified via security questions and employee ID.
- Temporary bypass codes will be issued for up to 24 hours while you re-enroll.

INFO: Do NOT share bypass codes with anyone. They are single-use and expire in 24 hours.

3. Single Sign-On (SSO) via Okta

3.1 Accessing SSO Applications

• URL: https://company.okta.com. Login with company email and AD password plus MFA.

• All approved applications are listed in the Okta App Catalog.

• SSO-enabled apps: Microsoft 365, Salesforce, Jira, Confluence, Workday, Zoom, GitHub Enterprise, AWS Console.

4. Data Security and Classification

4.1 Data Classification Levels

• PUBLIC: Can be shared externally. Examples: press releases, product brochures.

• INTERNAL: For employees only. Examples: internal memos, project plans.

• CONFIDENTIAL: Restricted to specific teams. Examples: financial data, client contracts.

• RESTRICTED: Highest sensitivity. Encryption mandatory. Examples: trade secrets, PII, health data.

4.2 Handling Sensitive Data

• Always use company-approved storage: OneDrive or SharePoint. Never personal cloud storage.

• Encrypt RESTRICTED files before emailing using Microsoft AIP (Azure Information Protection).

• Do not print CONFIDENTIAL or RESTRICTED data without a secure print release code.

• Report accidental data exposure immediately to security@company.com.

5. Phishing and Social Engineering

5.1 Identifying Phishing Emails

• Check sender email domain carefully. Spoofed domains look similar: company-corp.com vs company.com.

• Hover over links before clicking to reveal the real URL destination.

• Legitimate IT staff will NEVER ask for your password via email or phone.

• Be suspicious of urgent requests, threats, or offers that seem too good to be true.

5.2 Reporting Suspicious Emails

• Use the Report Phishing button in Outlook (Home ribbon tab).

• Forward suspicious emails to: phishing@company.com

• Do NOT click any links or download attachments from suspicious emails.

• If you accidentally clicked a link: disconnect from network immediately and call IT Security: 1800-IT-SEC.

6. Device Security

6.1 Screen Lock Policy

• Windows: Auto-locks after 5 minutes of inactivity (enforced by Group Policy).

• Mac: System Preferences, Security, Require password immediately after sleep.

• Mobile: Must have 6-digit PIN or biometric lock enabled at all times.

6.2 Disk Encryption

• Windows: BitLocker is automatically enabled. Verify: Control Panel, BitLocker Drive Encryption.

- Mac: FileVault is automatically enabled. Verify: System Preferences, Security, FileVault tab.
- If encryption is not enabled, contact IT immediately. This is a compliance requirement.